

WebPwn Advanced Pentest Report

Target: http://holbertonschool.az

Date: 2026-05-25 20:53 | Generated by WebPwn Senior Pentest Module

Executive Summary

This report presents the findings of an advanced automated security assessment against http://holbertonschool.az. The assessment utilized senior-level heuristics to identify critical vulnerabilities across OWASP Top 10 categories. A total of 28 security findings were recorded.

Severity	Count
CRITICAL	4
HIGH	5
MEDIUM	8
LOW	2
INFO	14

Detailed Security Findings

#1 [CRITICAL] XSS — Session Hijack Payload (Generated)

Location: http://holbertonschool.az

CVSS Score: 9.3

Technical Details: XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

#2 [CRITICAL] RCE — Remote Code Execution (Exploited)

Location: http://holbertonschool.az

CVSS Score: 10.0

Technical Details: Command 'whoami' executed. Output detected: 'administrator'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

#3 [CRITICAL] CHAIN: JWT None Algorithm → Admin Privilege Escalation

Location: <http://holbertonschool.az>

CVSS Score: 9.8

Technical Details: JWT with 'alg:none' or weak HS256 secret allows forging tokens with arbitrary claims (e.g. role:admin). This bypasses all role-based access controls.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce RS256/ES256 algorithms. Reject 'none' algorithm. Validate all JWT claims server-side. Use short expiration times.

#4 [HIGH] Missing Header: Content-Security-Policy

Location: <http://holbertonschool.az>

CVSS Score: 7.5

Technical Details: CSP prevents XSS and data injection attacks by controlling allowed resource sources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#5 [HIGH] Missing Header: Strict-Transport-Security

Location: <http://holbertonschool.az>

CVSS Score: 7.5

Technical Details: HSTS forces HTTPS connections and prevents SSL-stripping attacks.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#6 [HIGH] 2FA — No Rate Limiting on OTP (Brute-force Possible)

Location: <http://holbertonschool.az>

CVSS Score: 7.5

Technical Details: Tested 7 OTP codes with no lockout or 429 response.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce max 5 attempts. Add exponential backoff and account lockout.

#7 [HIGH] CHAIN: CORS Misconfiguration → XSS → Session Theft

Location: <http://holbertonschool.az>

CVSS Score: 8.8

Technical Details: Permissive CORS allows malicious origins to make authenticated API requests. Combined with XSS, attacker can send victim's session cookies to a controlled server via cross-origin fetch.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict CORS to trusted origins. Do not use wildcard (*) with credentials. Set HttpOnly + Secure + SameSite on cookies.

#8 [HIGH] CHAIN: Open Redirect → Phishing → OAuth Token Steal

Location: <http://holbertonschool.az?redirect=http://evil.example.com>

CVSS Score: 7.4

Technical Details: An open redirect on the login page can be used to redirect OAuth authorization codes to an attacker-controlled server. The victim's session tokens are silently stolen.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Whitelist all redirect URLs. Never use user-supplied URLs in redirect_uri without strict validation. Implement state parameter in OAuth flows.

#9 [MEDIUM] Open Redirect

Location: <http://holbertonschool.az?redirect=http://evil.example.com>

CVSS Score: 6.1

Technical Details: Open redirect via 'redirect' parameter

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Validate redirect URLs against a whitelist. Do not use user-controlled data in redirect headers.

#10 [MEDIUM] Open Redirect

Location: <http://holbertonschool.az?return=http://evil.example.com>

CVSS Score: 6.1

Technical Details: Open redirect via 'return' parameter

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Validate redirect URLs against a whitelist. Do not use user-controlled data in redirect headers.

#11 [MEDIUM] Open Redirect

Location: <http://holbertonschool.az?next=http://evil.example.com>

CVSS Score: 6.1

Technical Details: Open redirect via 'next' parameter

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Validate redirect URLs against a whitelist. Do not use user-controlled data in redirect headers.

#12 [MEDIUM] Open Redirect

Location: <http://holbertonschool.az?url=http://evil.example.com>

CVSS Score: 6.1

Technical Details: Open redirect via 'url' parameter

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Validate redirect URLs against a whitelist. Do not use user-controlled data in redirect headers.

#13 [MEDIUM] Open Redirect

Location: <http://holbertonschool.az?to=http://evil.example.com>

CVSS Score: 6.1

Technical Details: Open redirect via 'to' parameter

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Validate redirect URLs against a whitelist. Do not use user-controlled data in redirect headers.

#14 [MEDIUM] Open Redirect

Location: <http://holbertonschool.az?goto=http://evil.example.com>

CVSS Score: 6.1

Technical Details: Open redirect via 'goto' parameter

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Validate redirect URLs against a whitelist. Do not use user-controlled data in redirect headers.

#15 [MEDIUM] Missing Header: X-Frame-Options

Location: <http://holbertonschool.az>

CVSS Score: 6.1

Technical Details: Missing X-Frame-Options allows clickjacking attacks (embedding site in iframes).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#16 [MEDIUM] 2FA — Not Implemented

Location: <http://holbertonschool.az>

CVSS Score: 5.9

Technical Details: No 2FA/MFA endpoint detected.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Implement TOTP-based 2FA (FIDO2/WebAuthn/RFC 6238) for all accounts.

#17 [LOW] Missing Header: X-Content-Type-Options

Location: http://holbertonschool.az

CVSS Score: 3.1

Technical Details: Missing header allows MIME-type sniffing, enabling content injection.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#18 [LOW] Missing Header: Referrer-Policy

Location: http://holbertonschool.az

CVSS Score: 3.1

Technical Details: Missing Referrer-Policy may leak sensitive URL information to third parties.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#19 [INFO] Technology Fingerprinting

Location: http://holbertonschool.az

CVSS Score: N/A

Technical Details: Technology detected: Nginx 1.24.0

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#20 [INFO] Web Crawler

Location: <http://holbertonschool.az>

CVSS Score: N/A

Technical Details: -

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#21 [INFO] AWS S3

Location: <http://holbertonschool.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://holbertonschool.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#22 [INFO] Infrastructure

Location: <http://holbertonschool.az>

CVSS Score: N/A

Technical Details: Company: 15.236.0.0/15

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#23 [INFO] IP Prefixes

Location: <http://holbertonschool.az>

CVSS Score: N/A

Technical Details: 3.165.203.0/24, 149.19.6.0/24, 2600:9000:24bb::/48, 3.175.206.0/23, 2600:1f60:1080::/48, 2600:1f60:60c0::/48, 2600:9000:1e49::/48, 216.244.38.0/23, 170.85.212.0/24, 2600:1f60:6000::/40...

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#24 [INFO] Missing Header: Permissions-Policy

Location: <http://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Missing Permissions-Policy allows access to powerful browser APIs (camera, mic, etc.).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#25 [INFO] Missing Header: Cross-Origin-Opener-Policy

Location: <http://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Missing COOP allows cross-origin pages to access window references.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#26 [INFO] Missing Header: Cross-Origin-Resource-Policy

Location: <http://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Missing CORP allows cross-origin pages to load this site's resources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#27 [INFO] Information Disclosure: X-Powered-By

Location: <http://holbertonschool.az>

CVSS Score: 2.0

Technical Details: Server technology disclosure may aid attacker fingerprinting.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Remove X-Powered-By header from all responses.

#28 [INFO] Information Disclosure: Server

Location: http://holbertonschool.az

CVSS Score: 2.0

Technical Details: Server version disclosure may aid attacker fingerprinting.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Configure web server to omit or genericize the Server header.
